

PRACTICE EXAM 2 OF 4 · EXAM STRATEGY - ALL DOMAINS

# Practice Exam 2

Twenty new questions. Same weighting, harder distractors.

QUESTIONS 20    WEIGHTING 30/26/24/20    PASS MARK 14 of 20

A development team must be allowed to create IAM roles for their own applications without waiting on the security team. Security must guarantee that no created role can exceed the permissions the developer already holds.

The company uses a single account for development.

### Which feature meets this requirement?

- ☐ A A service control policy on the development account
- ☐ B A permissions boundary on the developers' roles
- ☐ C An IAM group containing all developers
- ☐ D A session policy passed at assume-role time

◆ PAUSE AND DECIDE

## Which feature meets this requirement?

- A

 Service control policy  
*Caps everyone in the account including security, and cannot express 'no more than the creator already has'.*
- B

 Permissions boundary  
*Built precisely for safe delegation of role creation. It caps the maximum permissions any created role can hold.*
- C

 IAM group  
*Controls what developers can do, not what the roles they create are permitted to do.*
- D

 Session policy  
*Narrows one session. It does not constrain roles created for other principals to use later.*

### THE SIGNAL

SCPs cap an account. Permissions boundaries cap what a principal can create. Both are ceilings at different scopes.

A company must detect whether any object in its S3 buckets contains payment card numbers or personal identifiers. The buckets were populated by several teams over many years and the file formats vary.

An ongoing report is required, not a single audit.

**Which service should be used?**

- ☐ A Amazon GuardDuty
- ☐ B Amazon Inspector
- ☐ C Amazon Macie
- ☐ D AWS Config with a custom rule

◆ PAUSE AND DECIDE

## Which service should be used?

- A

 GuardDuty  
*Reads logs for malicious behaviour. It flags suspicious access to a bucket, not what objects contain.*
- B

 Inspector  
*Scans workloads and container images for software vulnerabilities.*
- C

 Macie  
*Purpose-built to discover and classify sensitive data inside S3 objects, with managed identifiers for these exact data types.*
- D

 Config custom rule  
*Evaluates bucket configuration such as encryption settings. It never opens an object.*

### THE SIGNAL

Macie reads objects. Inspector scans workloads. GuardDuty reads logs. Separate them by what they look at.

An application in account A must read objects from a bucket in account B, encrypted with a customer managed KMS key in account B. The role in A has s3:GetObject and the bucket policy permits it.

Requests fail with access denied.

### What is missing?

- ☐ A The KMS key policy in account B must permit the role in account A
- ☐ B Account A must create a KMS key with a matching alias
- ☐ C The bucket must be replicated into account A
- ☐ D KMS-encrypted objects cannot be read cross-account

◆ PAUSE AND DECIDE

## What is missing?

- A

 KMS key policy grant  
*Reading an encrypted object needs two permissions: read the object, and use the key. Only the first has been granted.*
- B

 Matching alias key  
*An alias is a name. A different key cannot decrypt data encrypted by the original.*
- C

 Replicate the bucket  
*An enormous workaround, and the replica would hit the same missing key permission.*
- D

 Not possible cross-account  
*An invented restriction. This is a common supported pattern.*

### THE SIGNAL

Encrypted object access always needs two grants. The question mentioning only object permissions is the clue.

A public web application behind an Application Load Balancer is receiving automated requests attempting cross-site scripting. Source addresses change constantly.

The team also wants to limit each client to five hundred requests per five minutes.

### Which solution meets both requirements?

- ☐ A Network ACLs denying the offending source ranges
- ☐ B AWS WAF with managed rules and a rate-based rule
- ☐ C AWS Shield Advanced on the load balancer
- ☐ D Security groups restricted to known client addresses

◆ PAUSE AND DECIDE

## Which solution meets both requirements?

A NACLs

*Layer 4 only. They cannot inspect an HTTP payload for scripting attempts, and chasing changing addresses is endless.*

C Shield Advanced

*Targets DDoS volume, not malicious payloads inside otherwise normal requests.*

B WAF managed plus rate-based rules

*Managed rule groups cover cross-site scripting, and a rate-based rule enforces the request limit. One service, both requirements.*

D Security groups

*It is a public application, so there is no known client list, and security groups cannot express a rate.*

### THE SIGNAL

Application-layer attack plus rate limiting means WAF. Volumetric flooding means Shield.

A company with two thousand employees uses Okta as its identity provider. It is growing from three AWS accounts to thirty.

Staff currently have separate IAM users per account, and an audit found active users belonging to former employees.

**Which solution meets this with the LEAST operational overhead?**

- ☐ A A hub account holding IAM users, with cross-account roles elsewhere
- ☐ B IAM Identity Center federated with Okta
- ☐ C A Lambda function reconciling IAM users against Okta nightly
- ☐ D An account password policy with ninety-day rotation

◆ PAUSE AND DECIDE

## Which solution meets this with the LEAST operational overhead?

- A

 Hub account with roles  
*Removes duplication but leaves two thousand IAM users to provision and deprovision by hand.*
- B

 Identity Center with Okta  
*Access follows the identity provider, so a leaver loses AWS access when disabled in Okta, and no per-account users remain.*
- C

 Custom Lambda reconciliation  
*Builds bespoke identity plumbing to replicate a managed feature. Custom code is rarely the least-overhead answer.*
- D

 Password policy  
*Credential hygiene, not lifecycle. A rotated password on a leaver's account is still an active account.*

### THE SIGNAL

Existing identity provider plus many accounts plus LEAST overhead is IAM Identity Center.

Compliance requires a record of what every security group looked like on any date in the last two years, across fifty accounts, plus notification when a group allows unrestricted inbound access.

The record must include the state before and after each change.

### Which solution meets these requirements?

- ☐ A CloudTrail logs aggregated into a single S3 bucket
- ☐ B AWS Config with an organisation aggregator and a Config rule with SNS
- ☐ C VPC Flow Logs with CloudWatch Logs Insights
- ☐ D GuardDuty with Security Hub aggregation

◆ PAUSE AND DECIDE

## Which solution meets these requirements?

- A

 CloudTrail aggregated  
*Records that an API call was made and by whom. It does not store the resulting resource state over time.*
- B

 Config with aggregator and rule  
*Config records configuration state over time, aggregates across accounts, and its rules evaluate compliance and notify.*
- C

 Flow Logs  
*Record traffic that flowed, not rule changes.*
- D

 GuardDuty and Security Hub  
*Threat detection and finding aggregation. Neither keeps a configuration timeline.*

### THE SIGNAL

'What did it look like before and after' is the definition of AWS Config. CloudTrail answers who, not what state.

An Amazon RDS database serves an application comfortably, but a nightly analytics job runs long queries that slow the application badly while it executes.

The business has raised no concern about availability and has not experienced a zone failure.

**What should the solutions architect implement?**

- ☐ A Convert the database to Multi-AZ
- ☐ B Create a read replica and point the analytics job at it
- ☐ C Increase the instance size by two sizes
- ☐ D Take more frequent automated backups

◆ PAUSE AND DECIDE

## What should the solutions architect implement?

A Multi-AZ

*Improves availability, explicitly not a concern here, and the standby serves no read traffic at all.*

C Larger instance

*Buys headroom permanently for a problem better solved by moving the workload elsewhere.*

B Read replica for analytics

*Moves the heavy read workload off the primary, which is exactly what read replicas exist for.*

D More backups

*Unrelated to query performance, and backup activity can add load rather than reduce it.*

### THE SIGNAL

The sentence removing the availability concern exists to eliminate Multi-AZ. Read load means read replica.

An application processes messages from an SQS standard queue. Operations report duplicate processing and a small set of malformed messages retrying indefinitely, delaying valid work.

Processing takes about fifty seconds per message. The visibility timeout is forty seconds.

### Which combination fixes both problems?

- ☐ A Increase the visibility timeout above processing time and add a dead-letter queue
- ☐ B Convert the queue to FIFO and extend retention
- ☐ C Enable long polling and reduce batch size
- ☐ D Add more consumers to clear the backlog

◆ PAUSE AND DECIDE

## Which combination fixes both problems?

- A

 Longer timeout plus DLQ  
*Fifty seconds of work under a forty second timeout causes the duplicates; the DLQ removes poison messages after N attempts.*
- B

 FIFO and retention  
*FIFO would mask duplicates at a throughput cost while leaving a misconfiguration in place. Retention affects neither problem.*
- C

 Long polling  
*Reduces empty receives and cost. It does not touch duplication or endless retries.*
- D

 More consumers  
*More consumers collecting messages that reappear mid-flight increases duplication.*

### THE SIGNAL

Compare processing time against visibility timeout whenever both appear. That arithmetic is the answer.

A media workflow runs six sequential steps, some taking hours. Failures must retry three times, then notify an operator and hold the job for inspection.

The logic currently lives in a script on an EC2 instance, and restarts lose all in-flight jobs.

**Which service should coordinate this?**

- ☐ A AWS Step Functions
- ☐ B An SQS queue between each pair of steps
- ☐ C EventBridge scheduled rules
- ☐ D A larger EC2 instance running the script as a service

◆ PAUSE AND DECIDE

## Which service should coordinate this?

- A

**Step Functions**  
*Ordered steps, declarative retry counts, error branches, human approval and durable state that survives restarts.*
- B

**Queues between steps**  
*Decouples the steps, but you still write all retry counting, branching and state tracking yourself.*
- C

**EventBridge schedules**  
*Triggers things at times. It does not track a job's state through a sequence.*
- D

**Bigger instance**  
*The problem is lost state on restart, which a larger instance does not address.*

### THE SIGNAL

A queue decouples components. Step Functions orchestrates a process. Retries and branches mean orchestration.

A company runs workloads across seventy accounts using EBS, RDS, DynamoDB and EFS. Each team manages its own snapshot scripts.

An auditor requires proof that every production resource is backed up under one retention policy.

**Which solution meets this with the LEAST operational overhead?**

- |                                                                                                               |                                                                                    |
|---------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------|
| <input type="checkbox"/> A AWS Backup with plans applied through AWS Organizations, plus Backup Audit Manager | <input type="checkbox"/> B Standardise the snapshot scripts and run them centrally |
| <input type="checkbox"/> C Enable each service's own automated snapshots and export an inventory              | <input type="checkbox"/> D AWS Config rules checking for recent snapshots          |

◆ PAUSE AND DECIDE

## Which solution meets this with the LEAST operational overhead?

- A

**AWS Backup with Organizations**  
*One policy across all four services and every account, with Audit Manager producing the compliance evidence.*
- B

**Centralised scripts**  
*Still bespoke code the company owns and maintains across seventy accounts.*
- C

**Per-service snapshots**  
*Four mechanisms, four retention settings, and a manual report. No single policy and no automatic evidence.*
- D

**Config rules**  
*Detects whether backups happened. It does not perform them.*

### THE SIGNAL

Many services, many accounts, one policy, plus evidence is the AWS Backup signature.

A gaming service uses a custom protocol over UDP. Client firmware has destination addresses compiled in and cannot be updated in the field.

Servers run in four Regions, and traffic must move to a healthy Region within seconds of a failure.

### Which service should be used?

- ☐ A Route 53 latency-based routing with a thirty second TTL
- ☐ B AWS Global Accelerator
- ☐ C Amazon CloudFront with custom origins
- ☐ D An Application Load Balancer in each Region

◆ PAUSE AND DECIDE

## Which service should be used?

- A

 Route 53 latency routing  
*Compiled-in addresses mean clients never perform a DNS lookup, so DNS routing cannot reach them at all.*
- B

 Global Accelerator  
*Two static anycast IPs suit compiled-in addresses, UDP is supported, and failover is in seconds independent of DNS.*
- C

 CloudFront  
*HTTP and HTTPS only. It cannot carry a custom UDP protocol.*
- D

 ALB per Region  
*ALBs are HTTP only, and this provides no mechanism to shift traffic between Regions.*

### THE SIGNAL

Static IPs plus UDP plus seconds-level failover is the Global Accelerator signature. Any one should prompt you.

Hundreds of concurrent Lambda functions each open a connection to an Amazon RDS for PostgreSQL database. During peaks the database refuses connections and invocations fail. The team must keep the relational database and cannot restructure the application. Functions must succeed rather than be throttled.

### Which solution addresses this?

- ☐ A Reserved concurrency on the Lambda function
- ☐ B Amazon RDS Proxy in front of the database
- ☐ C Migrate the data to DynamoDB
- ☐ D Add read replicas and spread connections across them

◆ PAUSE AND DECIDE

## Which solution addresses this?

- A

 Reserved concurrency  
*Protects the database by throttling functions, which the requirement that functions must succeed explicitly rules out.*
- B

 RDS Proxy  
*Pools and reuses connections so hundreds of functions share a small number of real ones, and all invocations succeed.*
- C

 Migrate to DynamoDB  
*Ruled out by the requirement to keep the relational database and avoid restructuring.*
- D

 Read replicas  
*The functions also write, and each replica has its own connection limit.*

### THE SIGNAL

Reserved concurrency throttles to protect. RDS Proxy pools so nothing is throttled. The requirement decides.

A machine learning team trains across fifty GPU instances reading the same one hundred and fifty terabyte dataset held in S3. They need aggregate throughput of hundreds of gigabytes per second.

Copying the dataset onto each instance's EBS volume takes hours and reading directly from S3 is too slow.

### Which storage solution should be used?

- ☐ A Amazon EFS in General Purpose mode
- ☐ B Amazon FSx for Lustre linked to the S3 bucket
- ☐ C io2 Block Express volumes on each instance
- ☐ D Amazon FSx for Windows File Server

◆ PAUSE AND DECIDE

## Which storage solution should be used?

- A

 EFS General Purpose  
*Shared and scalable, but not designed for hundreds of gigabytes per second.*
- C

 io2 per instance  
*Not shared, and it retains the hours-long copy the question complains about.*
- B

 FSx for Lustre linked to S3  
*Built for HPC throughput at this scale, and it presents the S3 bucket as a file system so the copy step disappears.*
- D

 FSx for Windows  
*SMB shares for Windows. Wrong protocol and wrong performance profile.*

### THE SIGNAL

Hundreds of GB/s plus HPC or ML plus data already in S3 is the FSx for Lustre signature.

An API Gateway and Lambda API serves three hundred partner organisations. One partner's faulty client sent fifty times its usual volume, exhausting Lambda concurrency and degrading the API for everyone.

The company wants per-partner limits without changing application code.

### Which solution meets this?

- ☐ A Reserved concurrency on the Lambda function
- ☐ B API Gateway usage plans with per-partner API keys
- ☐ C AWS WAF rate-based rules on the API
- ☐ D Rate-limiting logic inside the Lambda function

◆ PAUSE AND DECIDE

## Which solution meets this?

- A

 Reserved concurrency  
*Caps the total, so it throttles all three hundred partners equally rather than the one causing the problem.*
- C

 WAF rate-based rules  
*Limits by source IP, and partners may share addresses or use many, so it maps unreliably to partner identity.*
- B

 Usage plans with API keys  
*Purpose-built for per-consumer throttling. Each partner gets its own rate and burst limits, configured not coded.*
- D

 Code-based limiting  
*Excluded by the no-code-change requirement, and the request consumes capacity before being rejected.*

### THE SIGNAL

Per-consumer limits mean usage plans. Reserved concurrency protects the backend but cannot tell callers apart.

An analytics team runs about four hundred complex queries daily with joins across several large tables, and expects dashboards to respond in under two seconds. The data is fifteen terabytes in S3.

They currently use Athena and report both slow dashboards and rising cost.

**What should the solutions architect recommend?**

- ☐ A Add more partitions to reduce data scanned by Athena
- ☐ B Load the data into Amazon Redshift
- ☐ C Move the data into DynamoDB with global secondary indexes
- ☐ D Run the queries on an EMR cluster with Spark SQL

◆ PAUSE AND DECIDE

## What should the solutions architect recommend?

**A** More partitions

*Genuinely reduces cost per query, but Athena is not built for sub-second dashboards at four hundred queries a day.*

**C** DynamoDB with GSIs

*A key-value store. Joins across large tables are precisely what it cannot do.*

**B** Load into Redshift

*A warehouse built for frequent complex joins with fast predictable response. At this volume a cluster costs less than per-scan pricing.*

**D** EMR with Spark SQL

*Suited to heavy transformation rather than interactive dashboards, with the most operational overhead.*

### THE SIGNAL

Frequency and complexity move the answer from Athena to Redshift. Infrequent ad-hoc would reverse it.

A simulation runs across ninety-six EC2 instances that exchange data with one another continuously throughout each run.

Performance is far below expectation, and profiling shows the bottleneck is inter-node network latency rather than CPU or disk.

**Which change would MOST improve performance?**

- ☐ A Distribute the instances across three Availability Zones
- ☐ B Launch them in a cluster placement group with Elastic Fabric Adapter
- ☐ C Use a spread placement group
- ☐ D Attach io2 Block Express volumes to every instance

◆ PAUSE AND DECIDE

## Which change would MOST improve performance?

- A

 Spread across three AZs  
*Improves resilience and makes latency worse, because cross-zone traffic travels further.*
- B

 Cluster placement group with EFA  
*Packs nodes onto the same low-latency network segment, and EFA supplies the high-throughput interconnect these workloads need.*
- C

 Spread placement group  
*Deliberately separates instances onto distinct hardware, the opposite of what tightly coupled nodes want.*
- D

 io2 volumes  
*Addresses disk throughput, which profiling has explicitly ruled out.*

### THE SIGNAL

Resilience and latency pull in opposite directions here. Optimise for what the question asks.

A company's steady production workload costs about twenty-five thousand dollars monthly across EC2, Fargate and Lambda, and has been stable for three years.

The platform team expects to migrate several services to Graviton instance families and may shift workloads between two Regions.

**Which purchasing option is MOST appropriate?**

- |                                                                                 |                                                             |
|---------------------------------------------------------------------------------|-------------------------------------------------------------|
| <input type="checkbox"/> A Standard Reserved Instances for the current families | <input type="checkbox"/> B An EC2 Instance Savings Plan     |
| <input type="checkbox"/> C A Compute Savings Plan                               | <input type="checkbox"/> D Spot Instances across the estate |

◆ PAUSE AND DECIDE

## Which purchasing option is MOST appropriate?

- A

 Standard RIs  
*Locks to specific families and Regions, both of which the team says will change, and standard RIs cannot be converted.*
- B

 EC2 Instance Savings Plan  
*A slightly better rate bought by locking to one family in one Region, and it covers neither Fargate nor Lambda.*
- C

 Compute Savings Plan  
*Covers EC2, Fargate and Lambda, and applies automatically as families and Regions change.*
- D

 Spot  
*Steady production traffic cannot absorb interruption, and Spot provides no commitment discount for it.*

### THE SIGNAL

Three services plus changing families plus two Regions equals Compute Savings Plan. Flexibility outweighs the slightly better locked rate.

A media company stores user uploads in S3. A small number become very popular and are accessed constantly for months. Most are never opened after the first week, and there is no way to predict which will be which.

The company wants lower storage cost without risking slow access to any file.

### Which storage class should be used?

- ☐ A S3 Standard-IA with a lifecycle transition at seven days
- ☐ B S3 Intelligent-Tiering
- ☐ C S3 One Zone-IA
- ☐ D S3 Glacier Flexible Retrieval

◆ PAUSE AND DECIDE

## Which storage class should be used?

- A

 Standard-IA at seven days  
*Would push popular files into IA and charge retrieval on each of their many reads, potentially costing more than Standard.*
- B

 Intelligent-Tiering  
*Unpredictable per-object access is its exact purpose. Popular files stay hot, forgotten ones move down, and there are no retrieval fees between tiers.*
- C

 One Zone-IA  
*User uploads cannot be re-created, so single-zone durability is inappropriate.*
- D

 Glacier Flexible Retrieval  
*Minutes-to-hours retrieval risks slow access, which the question forbids.*

### THE SIGNAL

Unpredictable per-object access means Intelligent-Tiering. A pattern described by age would mean a lifecycle policy.

A three-tier application spreads its tiers across three Availability Zones. The application tier makes very frequent small calls to the database tier, producing a large cross-AZ data transfer charge.

The architecture team asks whether they should consolidate into one zone to save money.

### What should the solutions architect advise?

- ☐ A Consolidate all tiers into a single Availability Zone
- ☐ B Keep the multi-AZ design and reduce the call volume through caching or batching
- ☐ C Move the database into the application tier's subnet
- ☐ D Route internal traffic through a NAT gateway

◆ PAUSE AND DECIDE

## What should the solutions architect advise?

- A

 Consolidate into one AZ  
*Removes the charge by removing the resilience. Trading availability for a transfer saving is not acceptable.*
- C

 Same subnet  
*A subnet lives in one AZ, so this is option A in disguise. The database loses zone independence.*
- B

 Reduce the chattiness  
*Attacks the actual driver, which is call volume, while preserving the availability the design exists for.*
- D

 NAT gateway for internal traffic  
*Adds hourly and per-GB charges to traffic that currently pays neither. It increases cost.*

### THE SIGNAL

Never trade a resilience property for a cost saving. Reduce the traffic instead.

An account shows unexplained charges. Investigation finds two hundred unattached EBS volumes, four thousand snapshots going back five years, and twenty unassociated Elastic IP addresses.

The team wants to reduce the cost and stop it recurring.

**Which combination addresses this? (Choose two.)**

- ☐ A Delete the unattached volumes and Elastic IPs, and use Data Lifecycle Manager to expire old snapshots
- ☐ B Convert the unattached volumes from gp2 to gp3
- ☐ C Use Trusted Advisor cost optimisation checks on an ongoing basis
- ☐ D Purchase Reserved Instances to offset the charges

◆ PAUSE AND DECIDE

## Which combination addresses this? (Choose two.)

- A

 Delete waste, automate expiry  
Removes the current cost and stops snapshots accumulating again through automated retention.
- B

 gp2 to gp3  
*A real saving on volumes in use. These are attached to nothing, so the correct action is deletion.*
- C

 Trusted Advisor checks  
Surfaces idle volumes, unassociated addresses and low-utilisation resources continuously, addressing the recurrence.
- D

 Reserved Instances  
*Reservations apply to compute, not to EBS storage or Elastic IP charges.*

### THE SIGNAL

Two requirements, two answers. Fix what exists, then put detection in place so it does not return.

# Scoring Practice Exam 2

Compare against your Exam 1 result rather than looking at this score alone.

- ◆ **Improved by three or more.** The revision worked. Continue to Exam 3 after a day.
- ◆ **Roughly the same score, different questions wrong.** Knowledge is patchy rather than domain-specific. Review the confusion pairs module.
- ◆ **Same questions wrong as Exam 1.** A genuine knowledge gap. Rewatch that domain properly before Exam 3.
- ◆ **Lower than Exam 1.** Usually fatigue or rushing. Sit Exam 3 rested rather than immediately.

## ON THE EXAM

Questions 1 to 6 security, 7 to 11 resilience, 12 to 16 performance, 17 to 20 cost.